

NIST CSF 2.0 Maturity and Gap Assessment

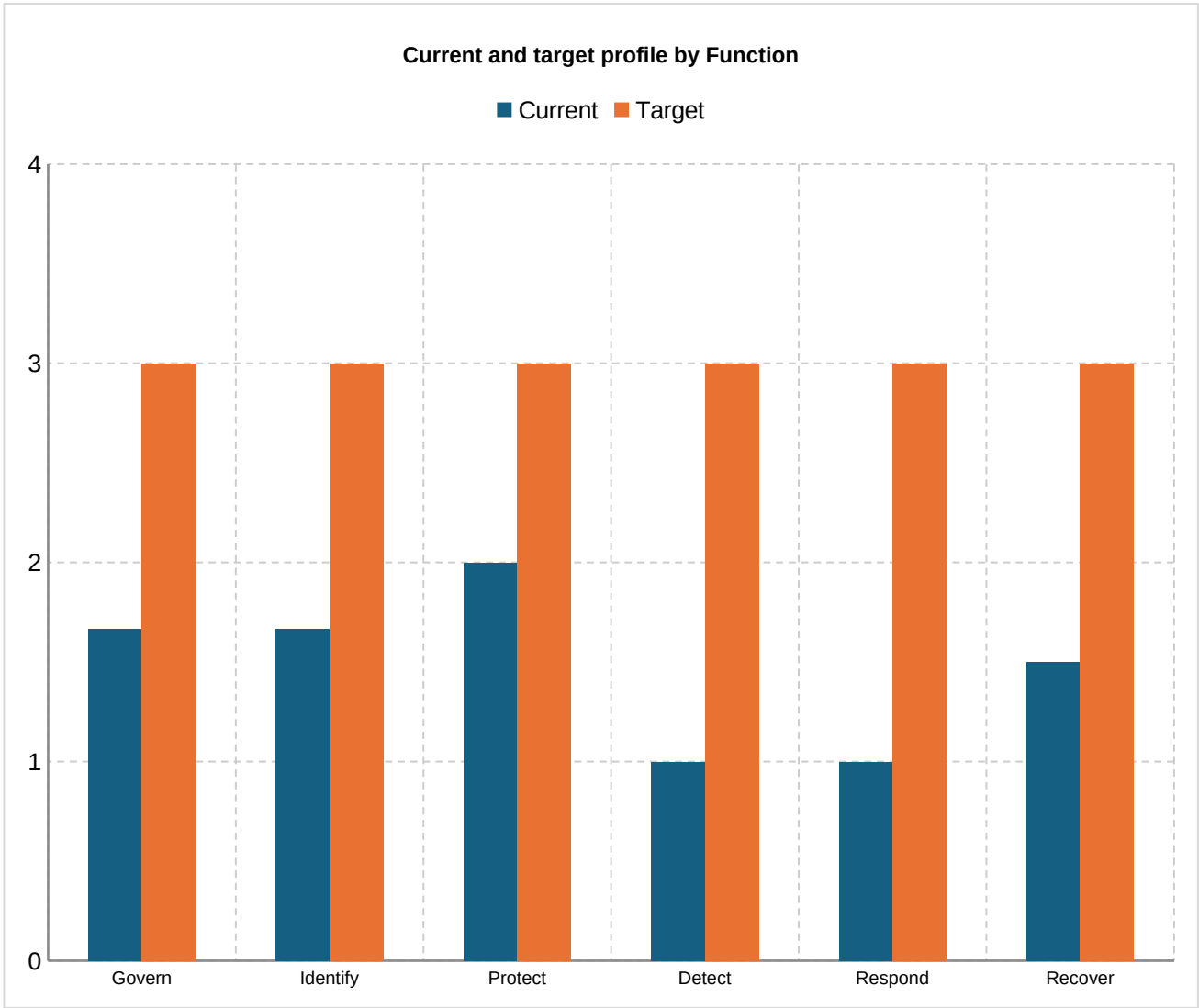
The Phone Boss ULTD | Category-level profile | 09/13/2026

Scope	The Phone Boss ULTD business operations, website, cloud services, customer and repair records, business devices, supplier accounts and customer devices in custody.
Assessment basis	Owner responses and ISO 27001 Portfolio Projects 1–10.
Current Implementation Tier	Tier 1: Partial, with several Tier 2 characteristics
Target Implementation Tier	Tier 2: Risk Informed
Current category coverage	39%
Target category coverage	75%
Important limitation	NIST CSF Tiers are not certifications or maturity scores. The numeric category scale in this workbook is a project assessment method, not an official NIST scale.

Executive conclusion	Priority
Current posture	The overall category coverage is approximately 39%. Protect is the strongest Function. Detect and Respond are the weakest because formal monitoring, event analysis and exercised incident-response processes are not established.
Tier conclusion	Tier 1 is the most defensible overall conclusion because policies and governance cycles are not formally approved or repeatable. Risk assessment and supplier awareness show progress toward Tier 2.
First priority	Approve governance and policy documents, establish inventories, and implement account and event monitoring.
Second priority	Exercise incident response and recovery, retain results, and use the CAPA process to verify improvement.

Function	Current average	Target average	Coverage
Govern	1.7	3.0	42%
Identify	1.7	3.0	42%
Protect	2.0	3.0	50%
Detect	1.0	3.0	25%
Respond	1.0	3.0	25%
Recover	1.5	3.0	38%

Function	Current	Target
Govern	1.666666666667	3
Identify	1.666666666667	3
Protect	2	3
Detect	1	3
Respond	1	3
Recover	1.5	3



Category-level assessment covering all 6 Functions and 22 Categories. Scores are evidence-based and preliminary.											
Function	Category ID	Category	Current score	Current state	Target score	Target state	Gap	Evidence and rationale	Priority action	Owner	Status
Govern	GV.OC	Organizational Context	2	Partially implemented	3	Implemented	1	Projects 1–2 define scope, issues, interested parties and dependencies, but approval is pending.	Approve and review the context and scope after material change.	Richard Vincent	Not started
Govern	GV.RM	Risk Management Strategy	2	Partially implemented	3	Implemented	1	Project 3 provides a scored risk register and treatments; objectives, appetite and recurring review remain incomplete.	Approve risk criteria, tolerance and the recurring review schedule.	Richard Vincent	Not started
Govern	GV.RR	Roles, Responsibilities, and Authorities	2	Partially implemented	3	Implemented	1	Richard Vincent is accountable and draft policies assign responsibilities; formal adoption is incomplete.	Approve responsibilities and document required external support.	Richard Vincent	Not started
Govern	GV.PO	Policy	1	Initial	3	Implemented	2	The Project 5 policy pack has been reviewed but is not signed, approved or acknowledged.	Approve, version, acknowledge and review the policy pack.	Richard Vincent	Not started
Govern	GV.OV	Oversight	1	Initial	3	Implemented	2	No completed management review, objective audit cycle or recurring performance review exists.	Conduct management review and schedule an independent audit.	Richard Vincent	Not started
Govern	GV.SC	Cybersecurity Supply Chain Risk Management	2	Partially implemented	3	Implemented	1	Project 8 assesses six suppliers and assigns review tiers; evidence collection is still in progress.	Complete enhanced and standard supplier reviews and annual monitoring.	Richard Vincent	Not started
Identify	ID.AM	Asset Management	1	Initial	3	Implemented	2	Assets, accounts and services are known informally, but no complete consolidated inventory exists.	Create hardware, software, service, account and data inventories.	Richard Vincent	Not started
Identify	ID.RA	Risk Assessment	2	Partially implemented	3	Implemented	1	A documented risk assessment exists, but vulnerability, threat-intelligence and change-trigger processes are incomplete.	Add vulnerability, threat, exception and change inputs to the risk cycle.	Richard Vincent	Not started
Identify	ID.IM	Improvement	2	Partially implemented	3	Implemented	1	Projects 6 and 10 identify findings and improvements; effectiveness has not completed an operating cycle.	Operate the CAPA log and verify closed actions.	Richard Vincent	Not started
Protect	PR.AA	Identity Management, Authentication, and Access Control	2	Partially implemented	3	Implemented	1	MFA covers critical supplier accounts; broader account inventory, recovery, session and privilege reviews are incomplete.	Complete six-month critical-account reviews.	Richard Vincent	Not started
Protect	PR.AT	Awareness and Training	2	Partially implemented	3	Implemented	1	Formal training is complete, but no documented phishing exercise or approved policy acknowledgement exists.	Approve the policy and complete an annual phishing exercise.	Richard Vincent	Not started
Protect	PR.DS	Data Security	2	Partially implemented	3	Implemented	1	Stripe handles card processing and customer records have protections, but passcode handling, retention and disposal evidence are inconsistent.	Standardize passcode authorization, retention and secure disposal.	Richard Vincent	Not started
Protect	PR.PS	Platform Security	2	Partially implemented	3	Implemented	1	Endpoint controls and public-code practices exist, but no consolidated baseline or consistent logging evidence is retained.	Document device baselines, updates, configurations and logs.	Richard Vincent	Not started
Protect	PR.IR	Technology Infrastructure Resilience	2	Partially implemented	3	Implemented	1	Business records have been restored and alternate suppliers exist; website and evidence-repository testing is incomplete.	Back up the evidence repository and complete restoration testing.	Richard Vincent	Not started
Detect	DE.CM	Continuous Monitoring	1	Initial	3	Implemented	2	No formal continuous-monitoring process covers business accounts, devices, suppliers and website events.	Enable and review available alerts and maintain a monitoring log.	Richard Vincent	Not started
Detect	DE.AE	Adverse Event Analysis	1	Initial	3	Implemented	2	No defined workflow consistently correlates, analyzes, scopes and declares adverse events.	Create event triage, severity and incident-declaration criteria.	Richard Vincent	Not started
Respond	RS.MA	Incident Management	1	Initial	3	Implemented	2	A draft incident policy exists, but it is not approved or exercised.	Approve the plan and conduct a tabletop exercise.	Richard Vincent	Not started
Respond	RS.AN	Incident Analysis	1	Initial	3	Implemented	2	No operating evidence shows investigation steps, root-cause analysis or evidence preservation.	Create a lightweight investigation and evidence-handling checklist.	Richard Vincent	Not started
Respond	RS.CO	Incident Response Reporting and Communication	1	Initial	3	Implemented	2	Notification principles exist in draft form, but contacts, triggers and tested communications are incomplete.	Approve the communications matrix and test notification procedures.	Richard Vincent	Not started
Respond	RS.MI	Incident Mitigation	1	Initial	3	Implemented	2	Containment and eradication actions are not formally documented or tested.	Document common containment actions and test them in a tabletop.	Richard Vincent	Not started
Recover	RC.RP	Incident Recovery Plan Execution	2	Partially implemented	3	Implemented	1	Some records were restored successfully; formal website restoration, recovery criteria and test records remain incomplete.	Complete and document restoration testing and recovery closure criteria.	Richard Vincent	Not started
Recover	RC.CO	Incident Recovery Communication	1	Initial	3	Implemented	2	No approved recovery-communication process or exercise evidence exists.	Define recovery update recipients, methods and approval steps.	Richard Vincent	Not started

NIST CSF 2.0 Implementation Tier Assessment

Tiers characterize the rigor of risk governance and management. They do not certify the organization.

Dimension	Current evidence	Current characteristic	Current tier	Target characteristic	Target tier	Required change
Cybersecurity risk strategy	Risk register and treatments exist; approval, objectives and recurring review are incomplete.	Risk practices occur but are not yet formally approved and consistently operated.	Tier 1: Partial	Risk practices are approved and directly informed by business needs.	Tier 2: Risk Informed	Approve the method, risk tolerance, objectives and review schedule.
Risk awareness and prioritization	The owner understands material risks and has prioritized MFA, backups and supplier risk.	Risk awareness is present, but not all decisions follow a repeatable process.	Tier 2: Risk Informed	Risk awareness consistently informs business and technology decisions.	Tier 2: Risk Informed	Use the risk register for material purchases, changes and exceptions.
Repeatability	Projects document many activities, but operating cycles and effectiveness evidence are incomplete.	Practices remain irregular or project-based.	Tier 1: Partial	Core processes recur on an approved schedule with retained evidence.	Tier 2: Risk Informed	Operate the ISMS calendar, dashboard, CAPA and review cycles.
Supplier risk	Six suppliers are identified, scored and tiered; formal evidence collection is in progress.	Supplier risk is understood but not yet addressed consistently or formally.	Tier 2: Risk Informed	Critical supplier risks are reviewed and treated consistently.	Tier 2: Risk Informed	Complete reviews and monitor them annually and at onboarding.
Information sharing and response	Incident and communication policies are drafts; no formal exercise has been completed.	Incident information processes are informal.	Tier 1: Partial	Response roles, contacts and reporting processes are approved and exercised.	Tier 2: Risk Informed	Approve the plan and complete a tabletop exercise.
Overall conclusion	Tier 2 characteristics exist in risk awareness and supplier risk, but governance, repeatability, monitoring and response evidence remain incomplete.	The weakest material characteristics determine the conservative overall Tier.	Tier 1: Partial	Risk-informed practices are approved and applied consistently across the owner-operated business.	Tier 2: Risk Informed	Complete the prioritized roadmap and reassess using operating evidence.

Actions are designed to move the business toward a defensible Tier 2 Current Profile.									
Priority	Action ID	CSF categories	Action	Owner	Target date	Status	Required evidence	Expected result	Effectiveness check
1	NIST-01	GV.PO, GV.OV, GV.RM	Approve the policy pack, risk method, objectives and annual governance calendar.	Richard Vincent	09/27/26	Not started	Signed documents and approved calendar	Governance becomes formally risk informed.	Confirm scheduled reviews produce dated evidence.
2	NIST-02	ID.AM	Create consolidated hardware, software, service, account and data inventories.	Richard Vincent	10/04/26	Not started	Completed inventories with owners and review dates	Assets and dependencies can be prioritized and protected.	Reconcile samples to actual devices, accounts and suppliers.
3	NIST-03	PR.AA	Complete the critical-account review for MFA, recovery, privilege, sessions and integrations.	Richard Vincent	10/11/26	Not started	Dated account review with sensitive values excluded	Authentication gaps are identified and treated.	Reperform the review for a sample of critical accounts.
4	NIST-04	DE.CM, PR.PS	Enable and review available security alerts and retain a monitoring log.	Richard Vincent	10/18/26	Not started	Alert settings and completed monitoring records	Account, device and website events are more likely to be detected.	Generate or observe a benign test alert and record handling.
5	NIST-05	DE.AE	Define event triage, severity, escalation and incident-declaration criteria.	Richard Vincent	10/18/26	Not started	Approved event-analysis checklist	Potential events are assessed consistently.	Apply the criteria during the tabletop exercise.
6	NIST-06	RS.MA, RS.AN, RS.CO, RS.MI	Approve the incident plan and conduct a documented tabletop exercise.	Richard Vincent	10/25/26	Not started	Scenario, timeline, decisions, communications and lessons learned	Response procedures become tested rather than theoretical.	Confirm gaps from the exercise enter the CAPA log.
7	NIST-07	RC.RP, RC.CO, PR.IR	Complete website and ISMS-evidence restoration tests and recovery communications.	Richard Vincent	11/01/26	Not started	Restoration records and recovery communication template	Recovery capability and evidence are demonstrated.	Restore samples and verify integrity and normal operation.
8	NIST-08	GV.SC	Complete six supplier reviews and establish annual/onboarding monitoring.	Richard Vincent	10/18/26	In progress	Six review decisions and treatment evidence	Supplier risks are handled consistently.	Confirm enhanced-review suppliers have complete current evidence.
9	NIST-09	PR.DS, PR.AT	Approve passcode handling and complete a phishing-recognition exercise.	Richard Vincent	10/13/26	Not started	Updated repair form and exercise record	Customer data handling and security awareness become evidenced.	Sample three repairs and review exercise lessons.
10	NIST-10	ID.IM	Review roadmap progress through the CAPA process and update the Current Profile.	Richard Vincent	12/15/26	Not started	Verified CAPAs and updated CSF Profile	Progress is measured and the Tier conclusion is reassessed.	Require closure evidence and effectiveness results before rescoreing.

Assessment Method and Source

Use the profile to prioritize improvement. Do not present it as NIST certification.

Category score	Assessment meaning
	0 Not established: no reliable design or evidence.
	1 Initial: ad hoc, informal, draft or not consistently operated.
	2 Partially implemented: meaningful controls or documents exist, but coverage or operating evidence is incomplete.
	3 Implemented: the category is addressed with approved, repeatable practices and current evidence.
	4 Managed and measured: practices are measured, reviewed and continually improved.

Interpretation rule	Detail
Numeric scale	This is a portfolio assessment method created for this workbook. NIST does not define this as an official maturity score.
Tier assessment	The Tier conclusion is a separate qualitative judgment based on the rigor and consistency of governance and risk-management practices.
Assessment depth	This is a category-level Current and Target Profile. A later audit may test individual Subcategories and operating evidence.
Evidence basis	Owner responses and ISO 27001 Portfolio Projects 1–10. Drafts do not prove operating effectiveness.
Official source	NIST Cybersecurity Framework 2.0, NIST CSWP 29, February 26, 2024: https://doi.org/10.6028/NIST.CSWP.29